

УПРАВЛІННЯ НЕПЕРЕРВНІСТЮ БІЗНЕСУ (BCM) ТА ISO 22301

Професійне керівництво для керівників та менеджерів
ЗМІСТ

БЛОК 1: СУТЬ BCM ТА ISO 22301

- 1.1 Що таке Business Continuity Management?
- 1.2 Проблеми, які вирішує BCM
- 1.3 Структура стандарту ISO 22301
- 1.4 Чому це критично важливо

БЛОК 2: ПЛАТФОРМА NASH 4.0

- 2.1 Революційний підхід до BCM
- 2.2 Архітектура платформи NASH 4.0
- 2.3 Ключовий функціонал платформи
- 2.4 Порівняння: Традиційний підхід vs NASH 4.0
- 2.5 Економічне обґрунтування

БЛОК 3: ПРАКТИЧНІ ПРИКЛАДИ

- 3.1 Універсальні сценарії (для будь-якої організації)
- 3.2 Кейс: Система охорони здоров'я (ЦГЗ України)
- 3.3 Кейс: Неприбуткова організація (НПО)

ЗАКЛЮЧЕННЯ

- Ключові висновки
- Наступні кроки
- Фінальна думка

УПРАВЛІННЯ НЕПЕРЕРВНІСТЮ БІЗНЕСУ (BCM) ТА ISO 22301

Професійне керівництво для керівників та менеджерів

Версія: 2.0

Дата: 9 жовтня 2025

Для: Учасників презентації NASH 4.0 Universal AI Partnership Platform

ЗМІСТ

БЛОК 1: СУТЬ BCM ТА ISO 22301 - Що таке Business Continuity Management - Проблеми, які вирішує BCM - Структура стандарту ISO 22301 - Чому це критично важливо

БЛОК 2: ПЛАТФОРМА NASH 4.0 - Революційний підхід до BCM - AI-функціонал платформи - Переваги над традиційними методами - Економічна ефективність

БЛОК 3: ПРАКТИЧНІ ПРИКЛАДИ - Універсальні сценарії для будь-якого бізнесу - Кейс: Система охорони здоров'я (ЦГЗ України) - Кейс: Неприбуткова організація (НПО)

БЛОК 1: СУТЬ BCM ТА ISO 22301

1.1 Що таке Business Continuity Management?

Визначення

Business Continuity Management (BCM) — це систематичний підхід до управління організацією, який забезпечує: - Продовження критичних операцій під час кризи - Швидке відновлення після інциденту - Мінімізацію збитків та захист репутації - Захист життя та безпеки людей

ISO 22301 — міжнародний стандарт, який визначає вимоги до системи управління неперервністю бізнесу (BCMS - Business Continuity Management System).

Ключова ідея

ISO 22301 відповідає на питання:

“Як гарантувати, що організація виживе при будь-якій кризі?”

Це не про уникнення проблем — це про **ГОТОВНІСТЬ** та **СТІЙКІСТЬ**.

1.2 Проблеми, які вирішує BCM

Без BCM (Типові проблеми):

СЦЕНАРІЙ: Кібератака на організацію

День 1, 03:00 - Ransomware зашифрував сервери

↓

Паніка: "Що робити?!"

↓

Немає плану дій

↓

День 1, 09:00 - Операції зупинені

Клієнти не обслуговуються

Втрата даних

↓

День 7 - Репутаційні втрати

Регуляторні штрафи

Клієнти йдуть до конкурентів

↓

Місяць 1 - Фінансова криза

Можлива ліквідація

Статистика: - 60% організацій без плану не виживають після major disaster - Середній час простою: 14 днів - Середні збитки: €2М-10М - 93% малих організацій закриваються протягом року після катастрофи

З BCM (Контрольована ситуація):

СЦЕНАРІЙ: Та сама кібератака

День 1, 03:00 - Ransomware зашифрував сервери
↓
03:05 - Автоматична сигналізація
↓
03:10 - Crisis Manager активує BCP
↓
03:15 - Мережа ізольована
↓
04:00 - Перехід на резервні системи
↓
День 1, 08:00 - Операції працюють у резервному режимі
Клієнти обслуговуються
Відновлення з backup
↓
День 1, 14:00 - Системи повністю відновлені
Дані синхронізовані
↓
День 2 - Post-incident review
Оновлення процедур
Організація сильніша

Результат: - Час простою: 11 годин (замість 14 днів) - Збитки: €50K (замість €2M+) - Репутація: покращилася ("надійна організація") - Клієнти: залишилися (навіть не помітили проблему)

Основні проблеми, які вирішує BSM:

Проблема	Як BSM вирішує
Хаос під час кризи	Чіткі процедури, кожен знає свою роль
Втрата даних	Регулярні backup, протестовані процедури відновлення
Тривалий простій	Резервні системи та workaround процедури
Репутаційні збитки	План комунікацій, швидка реакція
Регуляторні штрафи	Відповідність вимогам, документовані процеси
Залежність від ключових людей	Знання в системі, а не в головах
Фінансові втрати	Мінімізація часу простою = збереження доходу

1.3 Структура стандарту ISO 22301

ISO 22301 побудований на циклі **PDCA (Plan-Do-Check-Act)** — безперервному процесі вдосконалення.

10 основних розділів стандарту:

Розділ 4: КОНТЕКСТ ОРГАНІЗАЦІЇ

Мета: Зрозуміти своє середовище

Що визначаємо: - Хто stakeholders? (клієнти, регулятори, партнери, співробітники) - Що для них критично важливо? - Які зовнішні загрози? (стихійні лиха, кібератаки, пандемії, війни) - Які

внутрішні ризики? (обладнання, персонал, процеси)

Приклад:

Організація: IT-компанія

Stakeholders:

- ✓ Клієнти B2B (залежать від нашого SaaS)
- ✓ Співробітники (150 осіб)
- ✓ Інвестори (очікують ROI)

Зовнішні ризики:

- ✓ DDoS атаки
- ✓ Відключення електроенергії
- ✓ Проблеми з cloud провайдером

Внутрішні ризики:

- ✓ Ключові розробники (bus factor)
- ✓ Сервери (single point of failure)
- ✓ Код без документації

Розділ 5: ЛІДЕРСТВО

Мета: Топ-менеджмент ПОВИНЕН бути залученим

Вимоги: - ✓ CEO/Директор підписує BSM Policy - ✓ Призначає BSM Manager з повноваженнями - ✓ Виділяє бюджет та ресурси - ✓ Регулярно (щоквартально) переглядає статус BSM

Чому це важливо: - ✗ Без підтримки керівництва: BSM = формальність (папірець) - ✓ З підтримкою керівництва: BSM = частина культури організації

Розділ 6: ПЛАНУВАННЯ ★ (КРИТИЧНО)

Мета: Визначити ЩО захищати

Ключовий інструмент: BIA (Business Impact Analysis)

BIA відповідає на питання:

“Якщо ЦЕЙ процес зламається, як ШВИДКО ми помremo?”

Метафора: Організація = людина - Серце (критичні операції): RTO = 0 хвилин - Легені (важливі системи): RTO = 30 хвилин - Шлунок (допоміжні функції): RTO = 24 години - Волосся (некритичне): RTO = необмежено

Приклад BIA:

Процес	RTO	Макс.Простій	Критичність
Онлайн-продажі	30 хв	4 години	КРИТИЧНО
Обслуговування	2 год	8 годин	ВИСОКО
Email	4 год	1 день	СЕРЕДНЬО
Бухгалтерія	3 дні	1 тиждень	НИЗЬКО

RTO (Recovery Time Objective):

= Максимальний час простою, який можна допустити

RPO (Recovery Point Objective):

= Скільки даних можемо втратити

Фінансовий вплив:

Формула: Збиток/год = Втрачений дохід + Штрафи + Репутація

Приклад:

Онлайн-продажі зупинені:

- Втрачений дохід: €10K/год
- Штрафи (SLA): €5K/год
- Репутація: €15K/год

TOTAL: €30K/год × 4 години = €120K збитків

Вивід: Варто інвестувати в резервування!

Розділ 7: ПІДТРИМКА

Мета: Забезпечити ресурси

Що потрібно: 1. **Компетентні люди** (навчені, сертифіковані) 2. **Документація** (BCP плани, процедури) 3. **Комунікація** (екстрені контакти, альтернативні канали) 4. **Інформація** (backup даних, offline доступ)

Приклад Emergency Contact Tree:

ЕКСТРЕНА ЛАНЦЮГ ЗВ'ЯЗКУ	
Криза виявлена КИМ-ЗАВГОДНО	
↓	
Дзвонити НЕГАЙНО:	
[1] Crisis Manager	
ПІБ: [Ім'я]	
Тел: +XXX (основний)	
Тел: +YYY (резерв)	
Email/Telegram	
Якщо недоступний >5 хв:	
[2] Заступник Crisis Manager	
ПІБ: [Ім'я]	
Тел: +ZZZ	
Якщо обидва недоступні:	
[3] Директор	
ПІБ: [Ім'я]	
Тел: +AAA	

Розділ 8: ОПЕРАЦІЇ * (НАЙВАЖЛИВІШИЙ)**

Мета: Створити плани відновлення (BCP)

BCP (Business Continuity Plan) =
Покрокова інструкція “Що робити, якщо X зламалося”

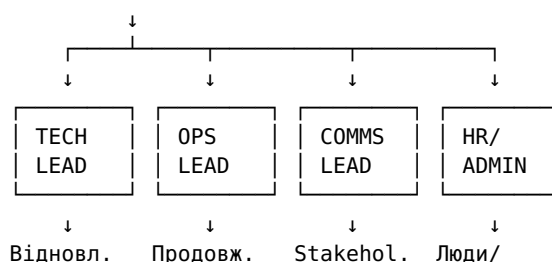
Структура хорошого BCP:

BCP: [НАЗВА СЦЕНАРІЮ]
КОЛИ АКТИВУВАТИ: • [Критерії для запуску цього плану]
ФАЗА 1: НЕГАЙНА РЕАКЦІЯ (0-2 години) ☐ 1. Безпека людей ☐ 2. Активація Crisis Team ☐ 3. Комунікація (персонал, клієнти)
ФАЗА 2: ТИМЧАСОВІ РІШЕННЯ (2-24 години) ☐ 4. Перехід на резервні системи ☐ 5. Workaround процедури ☐ 6. Моніторинг ситуації
ФАЗА 3: ПОВНЕ ВІДНОВЛЕННЯ (1-7+ днів) ☐ 7. Оцінка збитків ☐ 8. Відновлення основних систем ☐ 9. Повернення до нормальної роботи
ФАЗА 4: POST-INCIDENT REVIEW (Через 1-2 тижні) ☐ 10. Lessons Learned ☐ 11. Оновлення BCP
РЕСУРСИ: • Emergency контакти: [...] • Інструменти: [...] • Документи: [...] • Бюджет: €XX,XXX (pre-approved)

Вимоги ISO 22301 до BCP: - ✓ BCP для КОЖНОГО критичного процесу (з BIA) - ✓ BCP протестований (мінімум 1 раз на рік) - ✓ BCP доступний offline (якщо інтернет не працює?) - ✓ BCP зрозумілий (будь-хто може слідувати) - ✓ BCP актуальний (оновлюється після кожного інциденту)

Crisis Management Team (Структура):

CRISIS MANAGER (Командир) • Приймає BCI рішення • Координує команду • Має владу витрачати emergency budget
--



Розділ 9: ОЦІНКА ЕФЕКТИВНОСТІ

Мета: Перевіряй чи працює план

Типи тестування:

1. **Tabletop Exercise (Настільна гра)** - Час: 2-3 години - Команда обговорює сценарій за столом - Знаходить логічні проблеми - Частота: 2 рази на рік

2. **Simulation Exercise (Симуляція)** - Час: 4-8 годин - Притворюємось, що криза реальна - Тестуємо процедури на практиці - Клієнти НЕ зачеплені (sandbox) - Частота: 1 раз на рік

3. **Full Exercise (Повна тренування)** - Час: Повний день - РЕАЛЬНО перемикаємось на backup - Клієнти зачеплені (дуже ризиковано!) - Частота: Опціонально

Внутрішній аудит: - Хто: Незалежний аудитор (НЕ ВСМ-менеджер) - Коли: Мінімум 1 раз на рік - Що: Перевірка відповідності всім вимогам

Management Review: - Хто: CEO + Crisis Manager - Коли: Щоквартально - Що: Статус програми, інциденти, рішення на майбутнє

Розділ 10: ВДОСКОНАЛЕННЯ

Мета: Стати кращим кожен рік

Цикл вдосконалення:

- РІК 1: Базовий рівень
- └ ВСП плани написані
 - └ Вправи: відновлення 4 години
 - └ Знайдено проблеми
 - └ Проблеми виправлені
- РІК 2: Автоматизація
- └ Процедури автоматизовані
 - └ Вправи: відновлення 2 години ✓
 - └ Нові ризики додані
 - └ Плани оновлені
- РІК 3: Оптимізація
- └ Резервна площадка покращена
 - └ Вправи: відновлення 1 година ✓
 - └ AI впроваджений
 - └ Організація = resilient champion

Метрики вдосконалення:

Метрика	Рік 1	Рік 2	Рік 3
RTO досягнення	50%	75% ✓	95% ✓✓
Час відновлення	4 год	2 год ✓	1 год ✓✓
Знайдені проблеми	15	8 ✓	3 ✓✓

Готовність персоналу 60% 85% ✓ 95% ✓✓

1.4 Чому це критично важливо

4 основні причини сертифікації ISO 22301:

1. РЕГУЛЯТОРНІ ВИМОГИ

Хто вимагає: - Банки та страхові (фінансові регулятори) - Лікарні (міністерства охорони здоров'я) - Критична інфраструктура (уряд)
- Обробка персональних даних (GDPR + BSM)

Якщо НЕ сертифікований: - ✗ Штрафи €50K-500K+ - ✗ Втрата ліцензії - ✗ Кримінальна відповідальність (у крайніх випадках)

2. ВИМОГИ КЛІЄНТІВ

B2B клієнти питають:

"У вас є ISO 22301?"

Якщо НІ: - ✗ Великі контракти не підписують - ✗ Enterprise клієнти йдуть до конкурентів - ✗ Урядові тендери недоступні

Якщо ТАК: - ✓ Конкурентна перевага - ✓ Доступ до великих клієнтів - ✓ Вищі ціни (премія за надійність)

3. УПРАВЛІННЯ РИЗИКАМИ (ROI)

Розрахунок економіки:

ІНВЕСТИЦІЯ В ВСМ:

- └ Сертифікація: €50K (перший рік)
- └ З AI платформою: €5K ✗ (економія 90%)
- └ Підтримка: €10K/рік

ВАРТІСТЬ КРИЗИ БЕЗ ПЛАНУ:

- └ Один major incident: €2M збитків

ВАРТІСТЬ КРИЗИ З ПЛАНОМ:

- └ Той самий incident: €200K збитків

ЕКОНОМІЯ: €1.8M з ПЕРШОГО інциденту!

Ймовірність major incident: 15-20% на рік

Expected value економія: €270K-360K/рік

ROI: 540-720% у перший рік!

4. КОНКУРЕНТНА ПЕРЕВАГА

Маркетинг: - ✓ "ISO 22301 Сертифіковані" - ✓ = "Ми надійні, можете нам довіряти"

Особливо важливо для: - Фінансові послуги (гроші клієнтів) - Охорона здоров'я (життя людей) - Cloud/SaaS провайдери (бізнес клієнтів залежить від вас) - НПО (донори вимагають прозорості та надійності)

Результат: - → Більше клієнтів (довіра) - → Менше churn (впевненість) - → Вищі ціни (премія) - → Кращі інвестори (due diligence)

Філософія стандарту: RESILIENCE (Стійкість)

ISO 22301 НЕ про “уникнути проблем”
ISO 22301 про “ВИЖИТИ незважаючи на проблеми”

Метафора: Дерево під час шторму

Слабке дерево (крихке):
Шторм → дерево ламається → дерево мертве

Сильне дерево (resilient):
Шторм → дерево гнеться → шторм минув
→ дерево випрямилось → коріння глибше
→ дерево СИЛЬНІШЕ ніж до шторму

4 рівні зрілості:

РІВЕНЬ 1: FRAGILE (Крихкий)
Криза → Організація помирає

РІВЕНЬ 2: ROBUST (Міцний)
Криза → Організація витримує (але страждає)

РІВЕНЬ 3: RESILIENT (Стійкий) ← ISO 22301 ЦІЛЬ
Криза → Швидке відновлення за планом

РІВЕНЬ 4: ANTIFRAGILE (Анти-крихкий)
Криза → Організація стає СИЛЬНІШОЮ

БЛОК 2: ПЛАТФОРМА NASH 4.0

2.1 Революційний підхід до BSM

Проблема традиційного підходу:

Традиційна сертифікація ISO 22301:

🕒 ЧАС: 12-24 місяці
💰 ВАРТІСТЬ:
└ Консультант: €80K-150K
└ Certification audit: €10K-15K
└ Внутрішній час: 500-800 годин
└ TOTAL: €100K-180K

⚠ СКЛАДНІСТЬ: └ Розуміння 200+ вимог стандарту └ BIA для кожного процесу └ Написання BCP планів (десятки!) └ Створення процедур і документації └ Організація навчань └ Gap analysis перед аудитом
✖ ПРОБЛЕМИ: └ Знання тільки у консультанта └ Документи застарівають └ Складно підтримувати └ Дорога підтримка

Рішення: NASH 4.0 Universal AI Partnership Platform

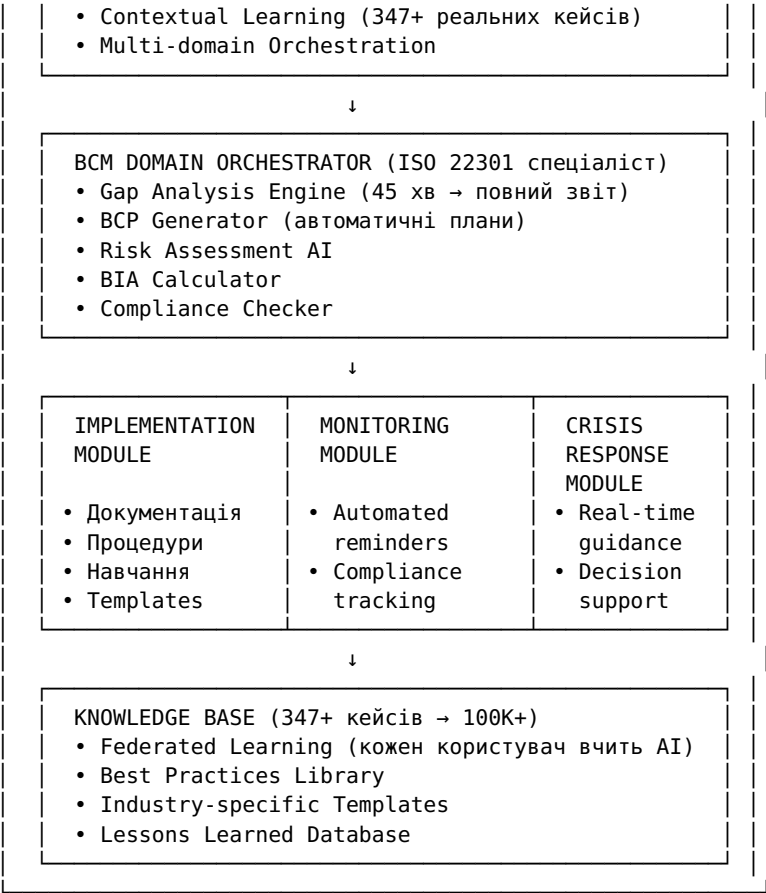
З AI платформою:

⏱ ЧАС: 3-6 місяців (4-8x швидше!)
💎 ВАРТІСТЬ: └ AI платформа: €200/міс × 6 = €1,200 └ Certification audit: €10K-15K └ Внутрішній час: 50-80 годин (AI 95%)! └ TOTAL: €12K-17K
💰 ЕКОНОМІЯ: €88K-163K (85-90%)
🤖 AI РОБИТЬ ЗА ВАС: └ ✔ Автоматичний gap analysis (45 хв) └ ✔ Генерація BCP планів └ ✔ Створення процедур └ ✔ Шаблони документів └ ✔ Рекомендації з 347+ кейсів └ ✔ Real-time допомога під час кризи
⚡ ПЕРЕВАГИ: └ Знання в системі (завжди доступні) └ Автоматичні нагадування про оновлення └ Постійне навчання з нових кейсів └ Прозора ціна

2.2 Архітектура платформи NASH 4.0

Модульна структура на принципах Single Responsibility:

NASH 4.0 UNIVERSAL AI PARTNERSHIP PLATFORM
CORE AI ENGINE (Claude Sonnet 4.5) • Natural Language Understanding



ПО РОЗДІЛАХ: └ Clause 4 (Context): 70% ✓ (Частково готово) └ Clause 5 (Leadership): 80% ✓ (Майже готово) └ Clause 6 (Planning): 30% ✗ (Потрібна робота) └ Clause 7 (Support): 40% △ (Потрібна робота) └ Clause 8 (Operation): 20% ✗ (CRITICAL GAP) └ Clause 9 (Evaluation): 10% ✗ (Не розпочато) └ Clause 10 (Improvement): 0% ✗ (Не розпочато)	
TOP 5 CRITICAL GAPS: 1. ✗ BCP плани відсутні (Clause 8) Пріоритет: CRITICAL Рішення: AI згенерує 12 BCP планів за 2 години Timeline: 1 тиждень 2. ✗ BIA не проведений (Clause 6) Пріоритет: HIGH Рішення: AI-guided BIA workshop Timeline: 3 дні 3. △ Навчання персоналу недостатнє (Clause 7) Пріоритет: MEDIUM Рішення: AI-generated training materials Timeline: 2 тижні 4. ✗ Тестування не проводилось (Clause 9) Пріоритет: HIGH Рішення: Організувати tabletop exercise Timeline: 1 місяць 5. △ Emergency contacts застаріли (Clause 7) Пріоритет: MEDIUM Рішення: Оновити контакти (Template готовий) Timeline: 2 дні	
ESTIMATED TIMELINE ДО СЕРТИФІКАЦІЇ: 3 традиційним підходом: 18-24 місяці 3 NASH 4.0 AI Platform: 4-6 місяців ✗ НАСТУПНІ КРОКИ: ☐ 1. Провести BIA (AI-guided) - 3 дні ☐ 2. Згенерувати BCP плани (AI) - 1 тиждень ☐ 3. Навчити Crisis Team - 2 тижні ☐ 4. Tabletop exercise - 1 місяць ☐ 5. Stage 1 Audit - 5 місяців	

2. AI-Generated BCP Plans

Що робить AI:

ВХІД:

- └ Критичний процес (з BIA)
- └ RTO/RPO вимоги
- └ Доступні ресурси
- └ Специфіка галузі

ПРОЦЕС (AI):

- └ Аналіз 347+ існуючих BCP кейсів
- └ Вибір relevant best practices
- └ Адаптація під вашу організацію
- └ Генерація детального BCP плану

ВИХІД (2 години на план):

- └ Структурований BCP документ
- └ Покрокові процедури (checklist)
- └ Emergency контакти (template)
- └ Ресурси та інструменти
- └ Критерії активації

Приклад згенерованого BCP:

BCP: ВІДМОВА ОСНОВНОГО IT DATA-ЦЕНТРУ Generated by NASH 4.0 AI Platform Організація: [Назва] Процес: Онлайн-платформа (e-commerce) RT0: 30 хвилин RP0: 5 хвилин
КОЛИ АКТИВУВАТИ: • Primary datacenter недоступний >10 хвилин • Впливає на >80% користувачів • Критичні системи down (payment, orders) DECISION MAKER: Crisis Manager або CTO
ФАЗА 1: НЕГАЙНА РЕАКЦІЯ (0-30 хвилин)
□ 1. АВТОМАТИЧНЕ ПЕРЕКЛЮЧЕННЯ (Якщо налаштовано) □ Автоматичний failover на DR datacenter Технологія: [AWS Route53 / Azure Traffic Manager] Час переключення: <5 хвилин Перевірка: https://status.company.com/health □ 2. ЯКЩО АВТОМАТИКА НЕ СПРАЦЮВАЛА - РУЧНЕ ПЕРЕКЛЮЧЕННЯ Ответственный: DevOps Lead або CTO □ Крок 1: Підключитися до DR Control Panel URL: https://dr.company.com/admin Login: [в Password Manager - 1Password] □ Крок 2: Виконати failover script Command: <code>./scripts/failover-to-dr.sh --confirm`</code> Локація: /opt/dr-scripts/ (на DR jumpbox) Очікуваний час: 10-15 хвилин □ Крок 3: Перевірити всі критичні сервіси ✓ Web frontend: https://www.company.com ✓ API: https://api.company.com/health ✓ Database: (query test accounts table) ✓ Payment gateway: (test transaction €0.01) □ 3. АКТИВАЦІЯ CRISIS TEAM (Паралельно з переключенням) □ Crisis Manager надсилає SMS всім членам команди Template SMS: "PRIMARY DC DOWN. BCP активований.

War room: Zoom [link]. ЗАРАЗ."

- Zoom War Room:
Link: [постійне посилання]
Backup: Telegram group @crisis_team

□ 4. КОМУНІКАЦІЯ (ТЕРМІНОВО!)

- Внутрішня (персонал):
Channel: Slack #incidents
Message:
"🚨 PRIMARY DC FAILURE. Переключились на DR.
Не панікувати. Updates кожні 30 хв."
- Зовнішня (клієнти):
Канал: Status page + Email
Template:
"Ми виявили технічну проблему.
Команда працює над вирішенням.
Сервіс може працювати повільніше.
ETA: 30 хвилин. Updates: status.company.com"

Хто публікує: Comms Lead АБО Crisis Manager
Інструменти:
- Status page: Statuspage.io dashboard
- Email blast: Mailchimp emergency template

ФАЗА 2: СТАБІЛІЗАЦІЯ (30 хв - 4 години)

□ 5. МОНІТОРИНГ DR DATACENTER

- Перевірити performance:
 - Response time (мета: <200ms)
 - Error rate (мета: <0.1%)
 - Throughput (capacity достатня?)

Інструменти:
- Datadog dashboard: [link]
- Grafana: [link]

□ 6. ОЦІНКА PRIMARY DATACENTER

- Визначити причину збою:
Можливі причини:
 - a) Відключення електроенергії
 - Перевірити: Зв'язатися з DC provider
 - ETA відновлення?
 - b) Мережевий збій
 - Перевірити: Ping/traceroute
 - Зв'язатися з ISP
 - c) Hardware failure
 - Перевірити: IPMI/iLO консоль
 - Викликати DC hands (remote hands service)
 - d) Кібератака / DDoS
 - Активувати SECURITY incident response
 - Залучити InfoSec team

- Estimated Time to Repair (ETR):

Якщо ETR < 4 години:
→ Залишаємось на DR, чекаємо відновлення

Якщо ETR > 4 години:
→ Оптимізуємо DR для довгострокової роботи
→ Можливо потрібно масштабувати DR resources

- 7. SCALING DR (якщо ETR > 4 год)
 - Збільшити DR capacity:
 - Auto-scaling: Увімкнути (якщо було вимкнено)
 - Manual scaling: Додати 2-3 додаткові instances
 - Database: Збільшити connection pool
- Budget: €XXX pre-approved для emergency scaling
Approval: Crisis Manager може витратити
- 8. CUSTOMER SUPPORT
 - Збільшити Support team:
 - Викликати backup support agents (on-call)
 - Prepared FAQ: DR-related issues
 - Escalation path: Support → DevOps → CTO

ФАЗА 3: ВІДНОВЛЕННЯ PRIMARY (4+ години)

- 9. ВІДНОВЛЕННЯ PRIMARY DATACENTER
 - Primary DC знову online?
 - ✓ Перевірка: Ping, SSH accessible
 - ✓ Сервіси запуснені
 - ✓ Database replication працює
 - Data sync Primary ← DR
CRITICAL: Sync нові дані з DR назад в Primary!
Tool: Automated replication (MySQL replication)
Verify: Row count, checksums
 - Testing Primary (15-30 хв):
 - Smoke tests: Automated test suite
 - Load test: Поступово направляти traffic
 - Monitor: Errors, latency, stability
- 10. FAILBACK ДО PRIMARY
ВАЖЛИВО: Failback робити у non-peak hours!
Recommended time: 02:00-04:00 AM
 - Крок 1: Повідомити команду про failback
War room Zoom активна
 - Крок 2: Виконати failback script
Command: `./scripts/failback-to-primary.sh`
Monitoring: Real-time dashboards
 - Крок 3: Перевірити всі сервіси на Primary
Той самий checklist як у Фазі 1
 - Крок 4: Monitor протягом 2 годин
Впевнитись що все стабільно
- 11. КОМУНІКАЦІЯ - ALL CLEAR

- Клієнтам:
"Проблему вирішено. Всі системи працюють нормально.
Дякуємо за терпіння!"
- Внутрішня:
"Incident resolved. Primary DC відновлено.
Post-mortem meeting: [час/дата]"

ФАЗА 4: POST-INCIDENT REVIEW (Через 24-48 годин)

- 12. POST-MORTEM MEETING
Учасники: Crisis Team + Key Engineers
Agenda:
 - 1. Timeline відтворення:
 - Що сталося о котрій годині
 - Хто що робив
 - Скільки часу зайняло
 - 2. Що спрацювало добре ✓
Приклади:
 - Failover був швидким
 - Команда добре координувалась
 - Комунікація була чіткою
 - 3. Що спрацювало погано ✗
Приклади:
 - Автоматика не спрацювала (чому?)
 - DR capacity був недостатнім
 - Контакт DC provider затримався
 - 4. Action Items 📌
Для кожної проблеми:
 - Що виправити?
 - Хто відповідальний?
 - Deadline?
 - 5. Update BCP
 - Внести зміни в цей документ
 - Оновити процедури

Документувати в: Incident Report (Template в Notion)

РЕСУРСИ ТА КОНТАКТИ

🚨 EMERGENCY CONTACTS:

Crisis Manager:
└ ПІБ: [Ім'я Прізвище]
└ Тел: +XXX-XXX-XXXX (моб)
└ Email: crisis@company.com
└ Telegram: @username

CTO / Tech Lead:
└ ПІБ: [Ім'я Прізвище]
└ Тел: +XXX-XXX-XXXX

└ Email: cto@company.com

DevOps Lead:

└ ПІБ: [Ім'я Прізвище]
└ Тел: +XXX-XXX-XXXX

Primary Datacenter Provider:

└ Компанія: [DC Provider Name]
└ Support 24/7: +XXX-XXX-XXXX
└ Ticket system: <https://support.dcp provider.com>
└ Account ID: #XXXXXX

DR Datacenter Provider:

└ Компанія: [DR Provider]
└ Support: +YYY-YYY-YYYY
└ Account ID: #YYYYYY

✳ ІНСТРУМЕНТИ ТА ДОСТУПИ:

DR Control Panel:

└ URL: <https://dr.company.com/admin>
└ Credentials: 1Password → "DR Admin"

Monitoring:

└ Datadog: <https://app.datadoghq.com/dashboard/xxx>
└ Grafana: <https://grafana.company.com>
└ Status page: <https://status.company.com/admin>

Communication:

└ War Room Zoom: [постійне посилання]
└ Slack: #incidents channel
└ Telegram: @crisis_team group
└ Email templates: [Google Docs folder]

Documentation:

└ Runbooks: /docs/runbooks/
└ Network diagrams: /docs/architecture/
└ DR Procedures: /docs/dr/
└ Contact lists: /docs/contacts/

💰 БЮДЖЕТ:

Pre-approved Emergency Budget: €10,000

└ Може витратити: Crisis Manager або CTO
└ На що: DR scaling, emergency services, vendors
└ Approval >€10K: Потрібен Директор

📋 КРИТЕРІЇ УСПІХУ:

RT0: 30 хвилин

RPO: 5 хвилин (max data loss)

Вважається успішним якщо:

- ✓ Failover to DR < 30 хв
- ✓ Service availability > 99.5% під час incident
- ✓ Data loss < 5 хв
- ✓ Customer-facing communication < 15 хв після incident

- ✦ ПРИМІТКА: Цей BCP згенеровано AI на основі:
- Вашої BIA (RTO/RPO вимоги)
 - 347+ реальних datacenter failure кейсів
 - Best practices для вашої галузі
 - Ваших існуючих ресурсів та інструментів

- △ ВАЖЛИВО: Перед використанням:
1. Перевірте всі контакти (актуальні?)
 2. Протестуйте процедури (tabletop exercise)
 3. Адаптуйте під вашу специфіку
 4. Оновлюйте після кожного інциденту

Час створення: 2 години (vs 2-3 тижні вручну!)

3. Real-Time Crisis Support

Як це працює під час реальної кризи:

REAL-TIME AI ASSISTANT ПІД ЧАС КРИЗИ	
🚨 КРИЗА ВІЯВЛЕНА: Primary datacenter down	
Crisis Manager відкриває NASH 4.0 Platform:	
🗨 AI ASSISTANT: "Я виявив що активовано BCP 'Primary DC Failure'. ПОТОЧНИЙ СТАТУС: ✓ Фаза 1 завершена (15 хв тому) ✓ Failover на DR успішний ✓ Crisis Team активована 🔧 Фаза 2: Стабілізація (в процесі) НАСТУПНІ КРОКИ: ☐ Оцінити ETR Primary DC ☐ Масштабувати DR якщо ETR > 4 год ☐ Update status page (20 хв з моменту incident) ⚠ ПОПЕРЕДЖЕННЯ: DR capacity при 75%. Рекомендую scaling через 1 год якщо Primary не відновиться."	
Crisis Manager: "Який ETR від DC provider?"	
🗨 AI: "Немає інформації в системі. РЕКОМЕНДУЮ: 1. Зателефонувати DC provider: +XXX-XXX-XXXX (24/7 support) Account ID: #XXXXXX 2. Запитати: - Причина збою?	

- ETR (estimated time to repair)?
- Чи потрібна наша допомога?

3. Задokumentувати відповідь тут:
[поле для вводу]

Я оновлю timeline та наступні кроки автоматично."

Crisis Manager вводить: "ETR: 6 годин (electrical)"

🤖 AI: "ETR 6 годин - це > 4 години."

РЕКОМЕНДАЦІЇ:

1. 📈 МАСШТАБУВАТИ DR (ТЕРМІНОВО)

Я підготував команди:

```

ssh dr-jumpbox

./scripts/scale-up.sh --instances=3

```

Вартість: ~€500 за 6 годин

(В межах pre-approved €10K budget)

2. 📄 ОНОВИТИ STATUS PAGE

Я підготував повідомлення:

[показати draft]

3. 👥 ЗБІЛЬШИТИ SUPPORT TEAM

Викликати backup agents:

- [Ім'я 1]: +XXX-XXX-XXXX

- [Ім'я 2]: +YYY-YYY-YYYY

4. ⌚ ЗАПЛАНУВАТИ FAILBACK

Рекомендований час: Сьогодні 02:00 AM

(6 год ETR + 2 год buffer = 08:00 відновлення

+ failback у non-peak hours)

Виконати рекомендації? [Так] [Ні] [Частково]"

ПЕРЕВАГИ REAL-TIME AI:

- ✓ Не забуває кроки (людина може забути в стресі)
- ✓ Знає best practices з 347+ кейсів
- ✓ Готує команди та повідомлення (copy-paste ready)
- ✓ Відстежує timeline (коли що робити)
- ✓ Нагадує про deadlines (status update через 20 хв!)
- ✓ Документує все автоматично (для post-mortem)

4. Federated Learning System

Як платформа стає розумнішою:

FEDERATED LEARNING: КОЛЕКТИВНИЙ ІНТЕЛЕКТ

ПОТОЧНИЙ СТАН (жовтень 2025):		
└ База знань: 347+ реальних кейсів		
└ Галузі: Healthcare, Finance, IT, Manufacturing, NGO		
└ Best practices бібліотека		
ЯК ВІДБУВАЄТЬСЯ НАВЧАННЯ:		
Крок 1: Користувач переживає інцидент		
↓		
Крок 2: NASH 4.0 документує incident (з дозволу)		
↓		
Крок 3: AI аналізує та анонімізує дані		
- Прибирає PII (personally identifiable info)		
- Зберігає patterns та рішення		
↓		
Крок 4: Додає в загальну базу знань		
↓		
Крок 5: ВСІ користувачі отримують покращені рекомендації		
ПРИКЛАД:		
2024: Лікарня А пережила ransomware атаку		
└ Виявили: backup в тій самій мережі (помилка!)		
└ Рішення: Offline air-gapped backup		
└ AI додав це в базу		
2025: Лікарня Б настраює backup		
└ AI попереджає: "Backup в одній мережі = ризик!"		
└ AI рекомендує: Air-gapped backup (з кейсу А)		
└ Лікарня Б уникає тієї самої помилки! ✓		
ЦІЛЬ:		
└ 2025: 347+ кейсів		
└ 2026: 10,000+ кейсів		
└ 2027: 50,000+ кейсів		
└ 2028: 100,000+ кейсів (найрозумніша ВСМ система!)		
ВСІ КОРИСТУВАЧІ ВИГРАВАЮТЬ:		
Кожен інцидент робить платформу розумнішою для всіх.		
Privacy protected. Knowledge shared. Everyone safer.		

2.4 Порівняння: Традиційний підхід vs NASH 4.0

Параметр	Традиційний підхід	NASH 4.0 AI Platform
⌚ ЧАС ДО СЕРТИФІКАЦІЇ	12-24 місяці	3-6 місяців (4-8х швидше)
💰 ВАРТІСТЬ	€100K-180K	€12K-17K (85-90% дешевше)
👤 ПОТРІБЕН КОНСУЛЬТАНТ?	Так (€80K-150K)	Ні (AI = консультант)
📅 СТВОРЕННЯ	Вручну (2-3 тижні/	

BCP	план)	AI (2 години/план)
🔍 GAP ANALYSIS	2-4 тижні	45 хвилин (AI)
📚 БАЗА ЗНАНЬ	Тільки консультанта	347+ кейсів (зростає)
🆘 ПІДТРИМКА ПІД ЧАС КРИЗИ	Потрібно звати консультанта	Real-time AI assistant
📄 ДОКУМЕНТАЦІЯ	Вручну, застаріває	Автоматична, завжди актуальна
🔄 ОНОВЛЕННЯ ПЛАНІВ	Вручну, раз на рік	AI нагадує та допомагає
🧑 НАВЧАННЯ ПЕРСОНАЛУ	Організовувати окремо	AI-generated materials
💡 LESSONS LEARNED	Тільки ваша організація	Вся спільнота (federated)

2.5 Економічне обґрунтування

ROI розрахунок для типової організації:

Сценарій: IT компанія, 150 співробітників, SaaS продукт

ІНВЕСТИЦІЇ В BCM
ВАРІАНТ А: Традиційний підхід └ Консультант: €120,000 (18 місяців) └ Certification audit: €12,000 └ Внутрішній час: 600 годин × €100/год = €60,000 └ TOTAL: €192,000 ВАРІАНТ Б: NASH 4.0 Platform └ Підписка: €200/міс × 6 міс = €1,200 └ Certification audit: €12,000 └ Внутрішній час: 60 годин × €100/год = €6,000 └ TOTAL: €19,200 ЕКОНОМІЯ: €172,800 (90%!) <
ЕКОНОМІЯ ВІД ЗАПОБІГАННЯ КРИЗАМ
Ймовірність major incident: 18% на рік БЕЗ BCM (якщо incident станеться): └ Час простою: 10 днів └ Втрачений дохід: €500K └ Репутаційні збитки: €200K └ Регуляторні штрафи: €100K └ TOTAL збиток: €800K З BCM (якщо incident станеться): └ Час простою: 8 годин

└ Втрачений дохід: €50K └ Репутаційні збитки: €0 (навіть +!) └ Регуляторні штрафи: €0 └ TOTAL збиток: €50K
ЕКОНОМІЯ ВІД 1 ІНЦИДЕНТУ: €750K Expected Value економія на рік: $18\% \times €750K = €135,000/\text{рік}$
TOTAL ROI (перший рік)
Інвестиція (NASH 4.0): €19,200 Вигода: └ Економія vs традиційний: €172,800 └ Expected value від запобігання: €135,000 └ TOTAL вигода: €307,800 ROI: $€307,800 / €19,200 = 1,603\%$ \$\$\$ Окупність: 0.8 місяців (менше місяця!)

БЛОК 3: ПРАКТИЧНІ ПРИКЛАДИ

3.1 Універсальні сценарії (для будь-якої організації)

Сценарій 1: Втрата доступу до офісу

Застосовано для: Будь-яка організація з фізичним офісом

Можливі причини: - 🚒 Пожежа - ⚡ Наводнення - 🏢 Проблеми з будівлею (аварія, ремонт) - 🦠 Карантин / Пандемія - ✂ Відключення комунікацій

ВСР (скорочена версія):

ВСР: ОФІС НЕДОСТУПНИЙ
КОЛИ АКТИВУВАТИ: • Офіс фізично недоступний >4 години • Впливає на >50% персоналу ФАЗА 1: БЕЗПЕКА ТА КОМУНІКАЦІЯ (0-2 год) □ 1. Перевірити безпеку всіх співробітників □ 2. Активувати Crisis Team (virtual meeting) □ 3. Повідомити персонал: "Перехід на remote work" □ 4. Повідомити клієнтів: "Працюємо віддалено"

ФАЗА 2: ПЕРЕХІД НА ВІДДАЛЕНУ РОБОТУ (2-24 год)

- 5. IT перевіряє VPN доступ для всіх
- 6. Роздати інструкції remote work
- 7. Налаштувати daily standups (Zoom)
- 8. Забезпечити critical ресурси з офісу (якщо можливо)

ФАЗА 3: ДОВГОСТРОКОВЕ РІШЕННЯ (1-7+ днів)

- 9. Оцінити коли офіс буде доступний
- 10. Якщо >2 тижні: Розглянути тимчасовий офіс
- 11. Страхове відшкодування (якщо застраховано)
- 12. Post-incident review

РЕСУРСИ:

- VPN доступ: [інструкція]
- Cloud storage: Google Drive / Dropbox
- Video conferencing: Zoom / Teams
- Emergency budget: €XXX для тимчасового офісу

Уроки з реальних кейсів (COVID-19 пандемія):

✗ **ЩО НЕ СПРАЦЮВАЛО** (компанії без плану):

- └ Паніка: "Ми не готові до remote work!"
- └ VPN не витримав навантаження (падав)
- └ Співробітники не мали ноутбуків (desktop в офісі)
- └ Критичні документи тільки в офісі (paper!)
- └ Продуктивність впала на 60-70%

✓ **ЩО СПРАЦЮВАЛО** (компанії з ВСМ):

- └ Плавний перехід за 48 годин
- └ Всі на cloud tools (вже були)
- └ VPN масштабовано заздалегідь
- └ Ноутбуки були у всіх
- └ Продуктивність: -10% (перший тиждень), потім норма
- └ Деякі навіть покращили продуктивність!

ВИВІД: Remote work readiness = must have (навіть якщо офіс доступний)

Сценарій 2: Втрата ключового співробітника

Застосовно для: Будь-яка організація

Можливі причини: - 🤒 Хвороба / Нещасний випадок - 📅 Звільнення (planned or unplanned) - 🏠 Тривала відпустка - 📦 Переведення на іншу позицію

Ризик: "Bus Factor" = 1 "Якщо ця людина потрапить під автобус, бізнес зупиниться"

BCP підхід:

BCP: ВТРАТА КЛЮЧОВОГО СПІВРОБІТНИКА

ПРЕВЕНТИВНІ ЗАХОДИ (ДО кризи):

1. ІДЕНТИФІКУВАТИ ключових людей:

- ☐ Провести "Bus Factor" аналіз

Питання: Хто володіє унікальними знаннями?

Приклад:

Співробітник		Критична роль	Backup?
Іван	Lead Developer	✗ HI	
	(тільки він знає legacy код)		
Марія	Client Manager	△ Partial	
	(key accounts)		

2. KNOWLEDGE TRANSFER (поки ще працюють!):

- ☐ Документувати критичні процеси
 - Runbooks (як робити X, Y, Z)
 - Процедури (step-by-step)
 - Паролі/доступи (в Password Manager)
 - Контакти (клієнти, vendor, партнери)
- ☐ Призначити backup людей
 - Навчити backup 80% завдань (не 100%)
 - Shadowing (працюють разом 1-2 тижні)
 - Регулярні knowledge sharing sessions

3. SUCCESSION PLANNING:

- ☐ Для кожної ключової ролі мати backup
 - Primary: [Ім'я]
 - Backup: [Ім'я]
 - Backup #2: [Ім'я] (якщо critical)

РЕАКТИВНІ ЗАХОДИ (КОЛИ вже пішов):

ФАЗА 1: НЕГАЙНА РЕАКЦІЯ (0-24 год)

- ☐ 1. Оцінити вплив
 - Питання:
 - Які завдання були в процесі?
 - Які deadlines під загрозою?
 - Які клієнти можуть постраждати?
- ☐ 2. Активувати backup людину
 - Якщо є backup → призначити
 - Якщо немає → розділити навантаження між командою
- ☐ 3. Отримати доступи
 - Паролі (з Password Manager)
 - Email forwarding
 - Системи, документи
- ☐ 4. Комунікація
 - Внутрішня: "Іван пішов. Марія тепер відповідає."
 - Клієнтам: "Новий контакт: Марія, [email/телефон]"

ФАЗА 2: КОРОТКОСТРОКОВО (1-4 тижні)

- 5. Тимчасове рішення
 - Option A: Перерозподілити роботу
 - Option B: Наймати freelancer (temporary)
 - Option C: Прискорити наймання replacement

- 6. Knowledge extraction
 - Якщо можливо exit interview:
 - Що важливо знати?
 - Які підводні камені?
 - Контакти, passwords, secrets

ФАЗА 3: ДОВГОСТРОКОВЕ РІШЕННЯ (1-3 місяці)

- 7. Наймання replacement
- 8. Onboarding та навчання
- 9. Update succession plan (щоб це не повторилось!)

LESSONS LEARNED:

Кейс: Стартуп втратив CTO (раптова хвороба)

✗ БЕЗ ПЛАНУ:

- Код тільки в голові CTO
- Deployment process невідомий
- Критичний bug → НЕ можемо виправити
- Product development зупинився на 2 місяці
- Компанія ледь вижила

✓ З ПЛАНОМ (інша компанія):

- Весь код документований
- Backup CTO (Senior Dev) знав 80% системи
- Deployment automated (CI/CD)
- Перехід за 1 тиждень
- Product: мінімальна затримка

ВИВІД:

"Знання в головах = ризик"
 "Знання в системі = безпека"

AI Платформа допомагає:

🤖 NASH 4.0 для цього сценарію:

1. АВТОМАТИЧНИЙ АНАЛІЗ BUS FACTOR
 - └ AI аналізує код commits (хто володіє яким кодом?)
 - └ AI аналізує документацію (де гар'и?)
 - └ AI генерує звіт: "Топ 5 ризиків"
2. ГЕНЕРАЦІЯ RUNBOOKS
 - └ AI створює documentation з існуючого коду
 - └ AI пропонує templates для процедур
 - └ AI нагадує оновлювати регулярно
3. SUCCESSION PLANNING TEMPLATES
 - └ Готові шаблони для кожної ролі
 - └ Knowledge transfer checklist
 - └ Навчальні матеріали

Сценарій 3: Кібератака (Ransomware)

Застосовно для: Будь-яка організація з ІТ системами (=всі)

Статистика: - 1 атака кожні 11 секунд (2025) - Середній викуп: €200K - 60% компаній платять викуп - 50% з тих хто заплатив все одно втрачають дані

BCP (критичні елементи):

BCP: RANSOMWARE АТАКА
ОЗНАКИ атаки: • Файли зашифровані (розширення змінилось) • Ransom note на екрані ("Pay Bitcoin to decrypt") • Системи недоступні • Антивірус знайшов malware
⚠ КРИТИЧНО: НЕ ПЛАТИТИ ВИКУП (майже ніколи!)
ФАЗА 1: ІЗОЛЯЦІЯ (0-30 хвилин) 🕒 □ 1. ІЗОЛЮВАТИ НЕГАЙНО (зупинити поширення) □ Відключити всі заражені машини від мережі Фізично: Витягнути network cable Або: Відключити Wi-Fi switch □ Вимкнути VPN (зовнішній доступ) □ Ізолювати backup сервери (КРИТИЧНО!) Якщо backup заразиться → все втрачено □ 2. НЕ ВИМИКАТИ заражені машини! Чому: RAM може містити ключ дешифрування Forensics потім зможуть витягнути □ 3. Активувати SECURITY INCIDENT RESPONSE □ Security team (або external SOC) □ Crisis Manager □ IT Lead
ФАЗА 2: ASSESSMENT (30 хв - 4 год) □ 4. Визначити SCOPE атаки Питання: - Скільки систем заражено? - Які дані зашифровані? - Чи є незаражені backup? - Який ransomware (strain)? Інструменти: - ID Ransomware (https://id-ransomware.malwarehunterteam.com/) - Upload ransom note → ідентифікує тип - Показує чи є безкоштовний decryptor □ 5. Перевірити BACKUP КРИТИЧНЕ питання: Чи є чисті backup?

- ☐ Перевірити останній clean backup
 - Коли зроблений?
 - Чи доступний?
 - Чи НЕ заражений?
- ☐ RPO calculation
 - Скільки даних втратимо?
 - (час між атакою та останнім backup)
- ☐ 6. Forensics (якщо час є)
 - Як вони проникли? (email? RDP? vulnerability?)
 - Коли? (можливо вже тижнями в системі)
 - Чи викрали дані ДО шифрування?
 - (сучасний ransomware = double extortion)

ФАЗА 3: RECOVERY (4-48 год)

- ☐ 7. РІШЕННЯ: Платити чи відновлювати з backup?

ПЛАТИТИ викуп якщо:

- ✗ Backup НЕмає або заражений
- ✗ RPO = неприйнятний (втратимо критичні дані)
- ✗ Відновлення триватиме >MTD
- ▲ І НАВІТЬ ТОДІ: Консультація з FBI/поліцією

ВІДНОВЛЮВАТИ з backup якщо:

- ✓ Backup чистий та доступний
- ✓ RPO прийнятний
- ✓ Відновлення в межах RTO

НАША РЕКОМЕНДАЦІЯ: Завжди відновлювати!
(Тому backup КРИТИЧНО ВАЖЛИВИЙ)

- ☐ 8. ВІДНОВЛЕННЯ з backup
 - ☐ Крок 1: Повністю очистити заражені системи
 - Format disks, reinstall OS
 - Не просто "видалити ransomware" - він може залишитись!
 - ☐ Крок 2: Закрити вразливість
 - Як вони проникли? Fix BEFORE відновлення!
 - Інакше: атака повториться через години
 - ☐ Крок 3: Відновити з backup
 - Послідовність:
 1. Критичні системи (production DB, etc)
 2. Основні системи (web, app servers)
 3. Допоміжні системи (email, documents)
 - ☐ Крок 4: Верифікувати дані
 - Integrity checks (checksums)
 - Тестові транзакції
 - Нічого не пропущено?
- ☐ 9. LEGAL / COMPLIANCE
 - ☐ Повідомити регулятора (GDPR: 72 години)
 - ☐ Повідомити клієнтів (якщо їх дані вкрали)
 - ☐ Police report (для страхової)

ФАЗА 4: POST-INCIDENT (Після recovery)

- 10. STRENGTHEN SECURITY
 - Update всі системи, patches
 - Змінити BCI паролі
 - Покращити email filtering
 - User training (phishing awareness)
 - Segmentation (щоб наступного разу не все зараз)
 - Offline backup (air-gapped!)
- 11. POST-MORTEM
 - Як проникли?
 - Чому backup був під загрозою?
 - Що покращити?
 - Update BCP

КРИТИЧНІ ПРЕВЕНТИВНІ ЗАХОДИ:

- ✓ 3-2-1 BACKUP RULE:
 - 3 копії даних
 - 2 різних носія (disk + tape)
 - 1 копія off-site (або offline/air-gapped)

КРИТИЧНО: Backup ПОВ інен бути OFFLINE!
Ransomware знаходить і шифрує online backup!

- ✓ REGULAR BACKUP TESTS:
Тестувати відновлення кожен квартал
"Untested backup = no backup"

- ✓ SEGMENTATION:
Критичні системи в окремих network segments
Якщо 1 заразиться → інші захищені

- ✓ PRINCIPLE OF LEAST PRIVILEGE:
Не кожному потрібен admin доступ!
Ransomware може шифрувати тільки те, до чого має доступ!

Реальний кейс:

✗ КОМПАНІЯ БЕЗ ВСМ:

Ransomware атака →

- └ Всі файли зашифровані (включно з backup!)
- └ Backup був в тій самій мережі
- └ Викуп: \$2M Bitcoin
- └ Заплатили → отримали decryptor
- └ Decryptor НЕ спрацював (50% файлів все одно втрачені)
- └ Бізнес зупинений на 3 тижні
- └ TOTAL збиток: \$5M + репутація

✓ КОМПАНІЯ З ВСМ:

Ransomware атака →

- └ Системи зашифровані
- └ Backup OFFLINE (air-gapped) - чистий! ✓
- └ Ізоляція за 15 хвилин
- └ Відновлення з backup: 18 годин
- └ RPO: 12 годин (втрачені останні 12 год даних)
- └ Вразливість закрыта (RDP без MFA)
- └ Security strengthened

- └ Викуп: НЕ платили
- └ TOTAL збиток: \$80K (operational costs)

ЕКОНОМІЯ: \$4.92M <

3.2 Кейс: Система охорони здоров'я (ЦГЗ України)

Організація: Центр громадського здоров'я МОЗ України

Контекст: - Лабораторна діяльність (діагностика, моніторинг епідемій) - Критично важливо для населення - Робота в умовах війни, енергокризи, пандемії

Специфічні ризики для охорони здоров'я:

УНІКАЛЬНІ ВИКЛИКИ ДЛЯ HEALTHCARE
1. ЖИТТЯ ЛЮДЕЙ ЗАЛЕЖАТЬ ВІД СИСТЕМ RTO часто = ХВИЛИНИ (не години/дні!) Приклад: - Реанімація (ІВЛ): RTO = 0 хвилин - Лабораторія (COVID тести): RTO = 4 години - Електронні медкарти: RTO = 30 хвилин
2. 24/7 ОПЕРАЦІЇ Немає "нерабочого времени" для maintenance Testing/failover треба робити без впливу на пацієнтів
3. РЕГУЛЯТОРНІ ВИМОГИ Суворе compliance (medical data = sensitive) Обов'язкова звітність при incident
4. СПЕЦИФІЧНІ РИЗИКИ - Відключення електроенергії (критично!) - Нестача медикаментів/обладнання - Пандемії (перевантаження системи) - Кібератаки на медичні дані (ransomware epidemic) - Військові дії (Україна context)

Впровадження ЦГЗ: Комплексна система BSM

1. Risk Management

ЦГЗ впровадив систему де ризики всіх структурних підрозділів ідентифікуються, оцінюються й переглядаються регулярно, з урахуванням змін у процесах і зовнішньому середовищі.

Визначаються:

- └ Ймовірні події:
 - Перебої електроенергії (висока ймовірність в Україні)
 - Відмова обладнання

- Кіберзагрози
 - Логістичні проблеми (війна)
- Потенційний вплив на процеси
- Лабораторна діагностика
 - Моніторинг епідемій
 - Звітність
- Способи реагування та заходи контролю

2. Превентивні заходи

ЦГЗ створив комплексну систему планів:

План DRP (Disaster Recovery Plan) Встановлює процедури відновлення інформаційних систем після збоїв, щоб мінімізувати час простою та зберегти дані й активи.

План BCP (Business Continuity Plan) Регламентує дії у разі кризових ситуацій, щоб забезпечити виконання бізнес-процесів навіть у мінімально прийнятному режимі.

План управління кризовими ситуаціями Описує процес ескалації, розподіл ролей та завдання із забезпечення безпеки персоналу, активів і репутації.

План кризових комунікацій Забезпечує оперативну, скоординовану комунікацію з внутрішніми та зовнішніми сторонами, мінімізує ризик дезінформації та визначає резервні канали зв'язку.

3. Governance: Комітет з управління кризовими ситуаціями

Комітет відповідає за ухвалення рішень щодо активації планів, розподіл ресурсів і координацію команд реагування.

Структура Комітету ЦГЗ:



4. Специфічні BCP для healthcare

Приклад: BCP “Відключення електроенергії в лабораторії”

BCP: ВІДКЛЮЧЕННЯ ЕЛЕКТРОЕНЕРГІЇ (ЦГЗ ЛАБОРАТОРІЯ)

КОНТЕКСТ:

Лабораторія має критичне обладнання:

- Холодильники з зразками (2-8°C)
- Морозильні камери з реагентами (-20°C, -80°C)
- ПЛР аналізатори (COVID/інші тести)
- Комп'ютери з даними пацієнтів

RT0: 15 хвилин (до критичних наслідків)

ФАЗА 1: НЕГАЙНА РЕАКЦІЯ (0-15 хв)

□ 1. АВТОМАТИЧНЕ ПЕРЕКЛЮЧЕННЯ НА ГЕНЕРАТОР

Обладнання:

- └ Генератор: [потужність, паливо]
- └ UPS (безперебійне живлення): 10-15 хв
- └ Автоматичне переключення: <10 секунд

Перевірка:

- ✓ Генератор запустився?
- ✓ Критичне обладнання працює?
 - Холодильники: Температура ОК?
 - Морозильники: Температура ОК?
 - ПЛР аналізатори: Завершити поточні тести

□ 2. ЯКЩО ГЕНЕРАТОР НЕ ЗАПУСТИВСЯ (План Б)

⌚ Час до критичних наслідків: 2-4 години

ПРИОРИТЕТИ:

Priority 1: Морозильники -80°C (найкритичніші)

Priority 2: Морозильники -20°C

Priority 3: Холодильники +2-8°C

Дії:

- Не відкривати холодильники! (зберуть холод 4-6 год)
- Телефонувати в енергокомпанію: ETR?
- Якщо ETR > 4 години:
 - Активувати "Евакуацію зразків"

□ 3. АКТИВАЦІЯ CRISIS TEAM

- Лабораторний менеджер → Комітет
- Оцінити ситуацію
- Координувати дії

ФАЗА 2: СТАБІЛІЗАЦІЯ (15 хв - 4 год)

□ 4. МОНІТОРИНГ ГЕНЕРАТОРА

- Перевірити паливо
 - Запас: [X] годин
 - Якщо < 12 годин → замовити дозаправку
- Працює стабільно?
 - Voltage, frequency в нормі?

□ 5. ЛАБОРАТОРНІ ОПЕРАЦІЇ

- Призупинити НЕ критичні тести
- Економимо енергію генератора

- ☐ Продовжити тільки критичне:
 - ✓ COVID/інфекційні захворювання (епід контроль)
 - ✓ Екстрені аналізи (якщо надійшли)
 - ✗ Планові дослідження (відкласти)
- ☐ 6. ЕВАКУАЦІЯ ЗРАЗКІВ (якщо немає генератора і ETR > 4 год) | РЕЗЕРВНА ЛОКАЦІЯ: [Лабораторія-партнер]
 Адреса: [...]
 Контакт: [ПІБ, телефон]

 ПРОЦЕДУРА:
 - ☐ Упакувати найкритичніші зразки
 - Біологічна безпека (proper containers!)
 - Температурний режим (термобокси з льодом)
 - Маркування (що, звідки, коли)
 - ☐ Транспортувати до резервної лабораторії
 Транспорт: [спеціальний транспорт з холодильником]
 Час в дорозі: ~30 хв
 - ☐ Документувати передачу
 Chain of custody (хто передав, хто отримав)
- ☐ 7. КОМУНІКАЦІЯ
 - ☐ Внутрішня (персонал):
 "Відключення електроенергії. Працюємо на генераторі.
 Призупинено планові тести. Критичні - продовжуємо."
 - ☐ Зовнішня (клієнти/лікарні):
 "Затримка обробки планових аналізів на [X] годин.
 Екстрені аналізи обробляються в звичайному режимі."
 - ☐ Регулятору (МОЗ):
 Якщо > 8 годин → formal notification required

ФАЗА 3: ВІДНОВЛЕННЯ (4+ год)

- ☐ 8. ПОВЕРНЕННЯ НА ЦЕНТРАЛЬНЕ ЕЛЕКТРОПОСТАЧАННЯ
 - ☐ Електроенергія відновлена?
 - ☐ Стабільна? (15+ хвилин без перепадів)
 - ☐ Переключити з генератора на центральну мережу
 - ☐ Генератор на standby (готовий до наступного разу)
- ☐ 9. ПЕРЕВІРКА ОБЛАДНАННЯ
 - ☐ Температурний режим ОК?
 Записати: мін/макс температура під час incident
 - ☐ Обладнання працює нормально?
 Калібрування (якщо потрібно)
 - ☐ Дані збережені?
 Вакцини працювали? Нічого не втрачено?
- ☐ 10. ПОВЕРНЕННЯ ЕВАКУЙОВАНИХ ЗРАЗКІВ (якщо було)
 - ☐ Транспортувати назад
 - ☐ Перевірити integrity (температурні логи)
 - ☐ Повернути в сховище
- ☐ 11. ВІДНОВЛЕННЯ НОРМАЛЬНИХ ОПЕРАЦІЙ

- ☐ Обробити backlog планових тестів
- ☐ Повідомити клієнтів: "Все відновлено"

ФАЗА 4: POST-INCIDENT REVIEW (Через 1-2 тижні)

☐ 12. LESSONS LEARNED

Питання:

- Генератор спрацював як очікувалось?
- Паливо вистачило?
- Евакуація зразків (якщо була) пройшла ОК?
- Комунікація була чіткою?
- Що покращити?

ACTION ITEMS:

Приклад:

- Збільшити запас палива з 24 год до 48 год
- Додати температурні сигналізації (SMS alerts)
- Укласти договір з 2-ю резервною лабораторією

☐ 13. ОНОВИТИ BCP

Внести зміни на основі досвіду

РЕСУРСИ (СПЕЦИФІЧНІ ДЛЯ HEALTHCARE)

🔌 BACKUP POWER:

- └ Генератор: [модель, потужність, локація]
- └ UPS: [модель, час роботи]
- └ Паливо: [запас, постачальник, телефон]
- └ Тестування: Щотижня (кожна субота 06:00)

🏢 РЕЗЕРВНА ЛАБОРАТОРІЯ:

- └ Назва: [Лабораторія-партнер]
- └ Адреса: [...]
- └ Контакт: [ПІБ, телефон 24/7]
- └ Capacity: [скільки зразків можуть прийняти]
- └ Договір: [номер, дата]

🚗 ТРАНСПОРТ ДЛЯ ЗРАЗКІВ:

- └ Спеціальний автомобіль з холодильником
- └ Водій 24/7: [ПІБ, телефон]
- └ Backup: [Альтернативна служба доставки]
- └ Термобокси: [локація, кількість]

📞 EMERGENCY CONTACTS (Healthcare-specific):

- └ Lab Manager: [ПІБ, телефон]
- └ Електрик (аварійний): [Компанія, телефон]
- └ Енергокомпанія (ETR запити): [номер, dispatch]
- └ Постачальник палива: [Компанія, 24/7 телефон]
- └ M03 (регулятор notification): [контакт]
- └ Резервна лабораторія: [контакт]

📁 COMPLIANCE:

- └ Temperature logs: Щогодини (автоматичні)
- └ Incident report: Template [посилання]
- └ M03 notification: Якщо >8 годин простою
- └ Sample integrity checks: Before/After incident

Результати впровадження в ЦГЗ

Практика ЦГЗ показує, що ефективність лабораторної діяльності значною мірою залежить від системного підходу до управління ризиками.

ДОСЯГНЕННЯ:

- ✓ Стійкість до енергокризи
 - Робота без перерв навіть під час масових відключень
 - Генератори + UPS забезпечують безперервність
- ✓ Готовність до кібератак
 - DRP план відпрацьований
 - Backup offline (захищений)
 - Регулярні тести відновлення
- ✓ Пандемійна готовність
 - BCP для перевантаження системи
 - Масштабування capacity
 - Комунікаційні протоколи
- ✓ Військова стійкість
 - Робота в умовах війни
 - Евакуаційні плани
 - Резервні локації

Інтегровані плани та діяльність Комітету з управління кризовими ситуаціями дозволяють Центру громадського здоров'я зберігати стійкість до криз і виконувати головну функцію: захист здоров'я населення України навіть у надзвичайних умовах.

3.3 Кейс: Неприбуткова організація (НПО)

Специфіка НПО

Унікальні характеристики:

ЩО РОБИТЬ НПО ОСОБЛИВИМИ?
1. МІСІЯ > ПРИБУТОК Рішення приймаються на основі impact, не ROI Приклад: Продовжити програму навіть якщо збиткова! бо люди залежать від неї
2. ЗАЛЕЖНІСТЬ ВІД ДОНОРІВ Фінансування = нестабільне Донор може вийти → фінансова криза
3. ОБМЕЖЕНІ РЕСУРСИ Малий бюджет на ВСМ

Мало персоналу (багато волонтерів)
4. РІЗНОМАНІТНІ STAKEHOLDERS
└─ Донори (платять)
└─ Бенефіціари (отримують допомогу)
└─ Волонтери (працюють)
└─ Суспільство (репутація)
└─ Регулятори (oversight)
5. РОБОТА В НЕСТАБІЛЬНИХ РЕГІОНАХ
Конфлікти, стихійні лиха, політична нестабільність
Безпека персоналу = критична
6. ПРОЗОРИСТЬ = КРИТИЧНА
Фінансова звітність публічна
Будь-який скандал = втрата донорів = смерть НПО

Типові ризики для НПО

ВІА для гуманітарної НПО:

Організація: Міжнародна гуманітарна НПО			
Місія: Допомога постраждалим від конфліктів			
Бюджет: €5M/рік Персонал: 50 (20 офіс + 30 field)			
CRITICAL PROCESSES (BIA):			
Процес	RTO	Макс.	Критичність
Доставка гум. допомоги в зону	12 г	48 г	КРИТИЧНО (люди залежать)
Безпека персоналу (комунікація з полем)	0 хв	N/A	КРИТИЧНО (життя людей!)
Прийом пожертвувань (онлайн)	48 г	7 дн	ВИСОКО (фінансування)
База бенефіціарів (хто отримав)	24 г	7 дн	ВИСОКО (підзвітність)
Фін.звітність для донорів	7 дн	1 міс	СЕРЕДНЄ (compliance)
TOP RISKS:			
1. Втрата основного донора (30%+ бюджету)			
Impact: △△△ КРИТИЧНО			
Likelihood: СЕРЕДНЄ (15-20% щороку)			
2. Безпека персоналу в полі (похищення, напад)			
Impact: △△△ КАТАСТРОФІЧНО			
Likelihood: НИЗЬКЕ (але наслідки жакливі)			

- | | |
|---|--|
| 3. Репутаційний кризис (скандал, fraud) | |
| Impact: $\Delta\Delta$ СЕРИОЗНО | |
| Likelihood: НИЗЬКЕ (але можливе) | |
| 4. Кібератака / втрата даних бенефіціарів | |
| Impact: $\Delta\Delta$ СЕРИОЗНО (GDPR, репутація) | |
| Likelihood: ЗРОСТАЄ (НПО = легкі цілі) | |
| 5. Закриття доступу до регіону (conflict escalation) | |
| Impact: $\Delta\Delta$ СЕРИОЗНО (не можемо працювати) | |
| Likelihood: СЕРЕДНЄ (нестабільні регіони) | |

ВСП Приклад: Втрата основного донора

Сценарій: Основний донор (35% бюджету) не продовжує грант

ВСП: ВТРАТА ОСНОВНОГО ДЖЕРЕЛА ФІНАНСУВАННЯ
(Donor withdrawal / Grant not renewed)

КОЛИ АКТИВУВАТИ:

- Донор, який покриває >30% бюджету, йде
- Грант не продовжений
- Фінансування закінчується <3 місяці

КОНТЕКСТ (Приклад):

Основний донор: Європейська Комісія (ЕС)

Грант: €1.75M/рік (35% бюджету)

Програми під загрозою:

└ Програма А: Допомога біженцям (€1M/рік)

└ Програма Б: Освіта дітей (€500K/рік)

└ Операційні витрати: (€250K/рік)

Персонал під загрозою: 15 осіб (з 50)

Бенефіціари постраждають: 5,000+ людей

ФАЗА 1: НЕГАЙНА РЕАКЦІЯ (0-7 днів)

□ 1. ОЦІНКА ВПЛИВУ (Day 1-2)

□ Скільки втрачаємо: €1.75M/рік

□ Коли гроші закінчатся: [дата]

Runway: 2.5 місяці (поточні резерви)

□ Які програми закриватимуться:

Priority 1 (зберегти):

- Програма А (core mission) ✓

Priority 2 (урізати):

- Програма Б (важлива, але не core) Δ

Priority 3 (закрити):

- Пілотні проекти ✗

□ Скільки людей втратять допомогу:

5,000 бенефіціарів (75% від Програми А+Б)

- Персонал:
15 осіб під ризиком звільнення

- 2. ЕКСТРЕННИЙ FUNDRAISING (Day 1-7)
ЦІЛЬ: Зібрати €500K за 30 днів (утримати 3 міс)

- EMERGENCY APPEAL до існуючих донорів
Template:
"Шановний [Donor],
Ми в кризі. ЕС не продовжили грант.
5,000 людей втратять допомогу через 60 днів.
Чи можете допомогти gap funding €XXX?"

Target donors (priority order):
1. [Donor B] - можливість €300K (історія support)
2. [Donor C] - можливість €150K
3. [Donor D] - можливість €100K
4. [Foundation E] - emergency grants available

Хто контактує: CEO ОСОБИСТО (not email!)
Deadline: Відповідь за 7 днів

- ПУБЛІЧНА КАМПАНІЯ (Individual donors)
Платформа: GoFundMe / GlobalGiving
Ціль: €50K від громадськості
Story: "Допоможіть нам продовжити місію"
Launch: День 3

- CORPORATE PARTNERSHIPS
Звернутися до 5 компаній з CSR бюджетами
Pitch: Short-term sponsorship

- 3. КОМУНІКАЦІЯ (Day 2-3)
КРИТИЧНО: Прозорість, але не паніка!

- Внутрішня (персонал):
Meeting: All-hands (Day 2)
Message:
"ЕС не продовжили грант. Ми в challenge режимі.
План дій:
- Emergency fundraising (активний)
- Можливі скорочення (15 positions at risk)
- Рішення через 30 днів
Ми боремося за кожну програму та позицію."

- Бенефіціарам:
"Тимчасові зміни можливі.
Ми робимо все щоб продовжити допомогу.
Будемо інформувати."

- Іншим донорам (ВАЖЛИВО!):
Проактивно повідомити (before чутки):
"ЕС grant ended. Ми активно шукаємо заміну.
Ваші програми НЕ під загрозою (different funding).
Фінансова стійкість = пріоритет."

- ПРЕС (опціонально):
⚠ Ризик: Може вплинути негативно на репутацію
✓ Вигода: Може привернути нових донорів
Рішення: Board of Directors

ФАЗА 2: РЕСТРУКТУРИЗАЦІЯ (7-30 днів)

- 4. РЕЗУЛЬТАТИ FUNDRAISING (Day 7 review)
Scenario A: Знайшли replacement funding
→ Продовжуємо як є (успіх!) ✓

Scenario B: Частковий success (€300-500K знайдено)
→ Урізати програми, зберегти core

Scenario C: Minimal success (<€300K)
→ Серйозні скорочення, можливо закриття програм

Scenario D: Fail (€0)
→ Managed wind-down, передача іншим НПО
- 5. OPERATIONAL CUTS (якщо Scenario B/C)
Принцип: Mission first, операційні витрати second

ФАЗА 1 CUTS (ЛЕГКІ):
 - Заморозити наймання (відкриті позиції)
 - Скоротити подорожі (тільки критичні)
 - Урізати офісні витрати:
 - Дешевший офіс / coworking
 - Скасувати subscriptions (non-essential)
 - Відкласти капітальні інвестиції
Економія: €50-80K/рік

ФАЗА 2 CUTS (СЕРЕДНІ):
 - Тимчасове зниження зарплат (-10-15%)
Пропозиція: Замість звільнень
Термін: 6 місяців (review after)
Apply до: Senior management first (показати приклад)
 - Скоротити Програму Б на 50%
 - Охопити 500 замість 1000 дітей
 - 3 співробітники замість 6
Економія: €300-400K/рік

ФАЗА 3 CUTS (ВАЖКІ - last resort):
 - Закрити пілотні проекти повністю
 - Layoffs (15 позицій)
 - Severance package (2 місяці зарплати)
 - Job placement assistance
 - Рекомендаційні листи
Економія: €500-700K/рік
- 6. ДИВЕРСИФІКАЦІЯ ФІНАНСУВАННЯ (Long-term)
Lessons: НЕ ЗАЛЕЖАТИ від одного донора!

НОВА СТРАТЕГІЯ:
 - Правило: Жоден донор >25% бюджету
 - Диверсифіковані джерела:
 - └ Institutional donors (40%): 4-5 різних

- └ Foundations (30%): 10+ grants
- └ Individual donors (20%): Recurring giving
- └ Earned income (10%): Консалтинг, тренінги

- Розвинути EARNED INCOME:
 - Консалтинг для інших НПО
 - Training workshops (платні)
 - Research / Publications
 Ціль: €500K/рік за 2 роки
- MEMBERSHIP PROGRAM:
 - Recurring donations: €10-50/міс
 - Ціль: 1,000 members × €20/міс = €240K/рік

□ 7. ЗАКРИТТЯ ПРОГРАМ (якщо не вистачає коштів)
MANAGED SHUTDOWN (не різке!)

- Визначити що закривати:
 - Criteria:
 - Найменш aligned з core mission
 - Найменш cost-effective (impact/€)
 - Є інші НПО які можуть перейняти
- Поступове закриття (3-6 місяців notice):
 - Finish existing commitments
 - Transfer бенефіціарів до інших НПО
 - Handover документації, lessons learned
- Комунікація з бенефіціарами:
 - "Програма закривається [дата].
 - Ми передаємо вас [інша НПО].
 - Ваша допомога продовжиться."

ФАЗА 3: ВІДНОВЛЕННЯ ТА ЗМИЦНЕННЯ (30-90 днів)

- 8. НОВА ФІНАНСОВА СТРАТЕГІЯ
 - Диверсифікований портфель донорів (виконати)
 - Emergency fund (ОБОВ'ЯЗКОВО!)
 - Ціль: 6 місяців операційних витрат
 - Build поступово: 10% surplus щороку
 - Зберігати: Liquid assets (швидкий доступ)
 - Довгострокові гранти (multi-year agreements)
 - Пріоритет: 3-5 річні гранти (стабільність)
- 9. STRENGTHENED GOVERNANCE
 - Board oversight посилений
 - Фінансовий комітет: Щоквартальний review
 - Risk committee: Моніторинг donor concentration
 - Financial policies оновлені:
 - Reserve policy (6 months minimum)
 - Donor diversification policy (max 25%)
 - Annual stress testing
- 10. POST-CRISIS REVIEW
 - Питання:
 - Чому ми так залежали від 1 донора?

- Чи могли передбачити?
- Що спрацювало в anti-crisis плані?
- Що покращити?

ACTION ITEMS для запобігання в майбутньому:

1. Emergency fund = must (будувати зараз)
2. Диверсифікація (правило 25%)
3. Earned income (менше залежність від грантів)
4. Stronger donor relationships (retention)
5. Regular scenario planning (quarterly)

РЕСУРСИ (NGO-SPECIFIC)

💰 EMERGENCY FUNDRAISING:

- └ Donor database: [CRM система]
- └ Emergency appeal templates: [Google Docs]
- └ Fundraising consultant (on retainer): [контакт]
- └ Crowdfunding platforms: GoFundMe, GlobalGiving

📊 ФІНАНСОВИЙ АНАЛІЗ:

- └ Budget model (scenario planning): [Excel]
- └ Cash flow projection: [оновлюється щотижня]
- └ Reserves: €XXX,XXX (3.2 місяці - ПОТРІБНО БІЛЬШЕ!)

🤝 ПАРТНЕРСЬКІ НПО (для handover):

- └ [НПО Партнер 1]: Similar mission, [контакт]
- └ [НПО Партнер 2]: [контакт]
- └ Coordination body: [UN Agency / Network]

👤 EMERGENCY CONTACTS:

- └ CEO: [ПІБ, телефон]
- └ CFO: [ПІБ, телефон]
- └ Board Chair: [ПІБ, телефон]
- └ Key donors (emergency):
 - └ [Donor A]: [контакт особи]
 - └ [Donor B]: [контакт особи]
- └ Legal counsel: [юрист, для layoffs/contracts]

📁 COMPLIANCE:

- └ Donor reporting: Continue (показати stability!)
- └ Auditor notification: [якщо material impact]
- └ Regulatory: [якщо є registration requirements]

Висновки для НПО

Ключові lessons для НПО ВСМ:

✓ ОБОВ'ЯЗКОВЕ для виживання НПО:

1. EMERGENCY FUND (6 місяців)
Більшість НПО живуть "місяць-в-місяць"
Emergency fund = life insurance
2. DONOR DIVERSIFICATION
Правило 25%: Жоден донор >25% бюджету
Краще 10 малих донорів ніж 1 великий

3. MULTIPLE REVENUE STREAMS
 - └ Institutional grants (foundations, governments)
 - └ Individual donors (recurring giving programs)
 - └ Earned income (consulting, training, research)
 - └ Corporate partnerships (CSR programs)
 4. TRANSPARENT COMMUNICATION

Криза? Бути відвертими з donors та stakeholders
Прозорість → довіра → підтримка
 5. MISSION-DRIVEN CUTS

Якщо треба різати: Зберегти core mission
Operations можна урізати, mission - ні
 6. PARTNERSHIPS

Інші НПО = не конкуренти, а партнери
Можуть перейняти програми якщо ви закриєтесь
 7. VOLUNTEERS ≠ FREE

Волонтери потребують координації, навчання
Включити volunteer management в BCM
 8. DATA PROTECTION CRITICAL

Beneficiary data = highly sensitive
GDPR breach → втрата довіри = смерть НПО
-

ЗАКЛЮЧЕННЯ

Ключові висновки

1. BCM - це не опція, це необхідність

ФАКТИ:

- └ 60% організацій БЕЗ плану не виживають після major disaster
- └ 93% малих організацій закриваються протягом року після катастрофи
- └ Середні збитки БЕЗ плану: €2М-10М
- └ Середні збитки з планом: €50К-200К (40-200х менше!)

ВИВІД: Питання не "чи станеться криза", а "коли станеться"

2. ISO 22301 = Перевірена система

ISO 22301 надає:

- ✓ Структуру (10 clauses - всі аспекти покриті)
- ✓ Best practices (перевірені роками)
- ✓ Міжнародне визнання (credibility)
- ✓ Continuous improvement (PDCA cycle)
- ✓ Certification (proof для клієнтів/регуляторів)

3. NASH 4.0 = Революція в BCM

Традиційний підхід → NASH 4.0:

- └ 12-24 місяці → 3-6 місяців (4-8х швидше)

- └ €100K-180K → €12K-17K (85-90% дешевше)
- └ 500-800 годин роботи → 50-80 годин (AI робить 95%)
- └ Знання у консультанта → Знання в системі (завжди доступні)
- └ Статична документація → Live система (нагадування, updates)
- └ Немає підтримки в кризі → Real-time AI assistant
- └ Локальні lessons → Federated learning (347+ кейсів)

4. ROI = Незаперечний

ПРИКЛАД: Типова IT компанія (150 осіб)

Інвестиція: €19,200 (NASH 4.0)

Вигода рік 1:

- └ Економія vs традиційний: €172,800
- └ Запобігання збиткам: €135,000 (expected value)
- └ TOTAL: €307,800

ROI: 1,603% (окупність <1 місяця!)

Кожен рік далі: €135K+ економія від запобігання crisis

5. Кожна галузь має специфіку, але принципи однакові

UNIVERSAL PRINCIPLES:

1. ЗНАЙ свої ризики (BIA, Risk Assessment)
2. МАЙ план (BCP для кожного critical process)
3. ТРЕНУЙСЯ (Exercises щороку мінімум)
4. ПОКРАЩУЙ (PDCA cycle, lessons learned)

INDUSTRY-SPECIFIC:

- └ Healthcare: RTO = хвилини, життя людей, 24/7
- └ NGO: Donor dependency, limited resources, mission first
- └ Finance: Regulatory, data security, instant transactions
- └ Manufacturing: Supply chain, machinery, just-in-time
- └ SaaS/Tech: Uptime SLAs, data backups, cyber resilience

AI Platform адаптується під кожен специфіку!

Наступні кроки

Для організацій, які хочуть впровадити BCM:

КРОК 1: ASSESSMENT (Тиждень 1)

- └ Скористатися NASH 4.0 Automated Gap Analysis
- └ 45 хвилин → повний звіт готовності

КРОК 2: PLANNING (Тиждень 2-4)

- └ AI-guided BIA (визначити critical processes)
- └ AI-generated BCP плани
- └ Crisis Team setup

КРОК 3: IMPLEMENTATION (Місяць 2-4)

- └ Навчання персоналу (AI materials)
- └ Testing (Tabletop exercise)
- └ Документація (AI templates)

КРОК 4: CERTIFICATION (Місяць 5-6)

- └ Stage 1 Audit (документи)
- └ Gap remediation
- └ Stage 2 Audit (certification)

TOTAL: 6 місяців до сертифікату <
(vs 12-24 місяці традиційно)

Демо NASH 4.0 Platform:

Контакт для демо:

[Контактна інформація]

Що побачите:

- └ Live Gap Analysis (45 хв)
- └ AI BCP Generation (real-time)
- └ Crisis Response Simulator
- └ Knowledge Base (347+ кейсів)
- └ ROI Calculator (для вашої організації)

Безкоштовна консультація:

30 хвилин з BCM експертом + AI demo

Фінальна думка

ISO 22301 відповідає на вічне питання:

“Що якщо завтра все зламається?”

БЕЗ BCM:

Паніка → Імпровізація → Хаос → Можливо смерть бізнесу

З BCM (ISO 22301):

План активовано → Передбачувані дії → Контроль → Вживання

З NASH 4.0 AI Platform:

План активовано → AI допомагає real-time → Швидше recovery →
Lessons додані в систему → Наступна криза = ще краща готовність
→ ANTIFRAGILE: Стаємо сильнішими з кожним випробуванням

ГОТОВНІСТЬ = ВИЖИВАННЯ
ВИЖИВАННЯ = ПРОЦВІТАННЯ

Час діяти — криза не чекає.

*Документ підготовлено для презентації NASH 4.0 Universal AI
Partnership Platform
Версія 2.0 | 9 жовтня 2025*